OWASP DEPENDENCY-TRACK

Community Meeting
March 2026

Organizational

- Community meetings are recorded and uploaded to YouTube
- Slides will be published in the `DependencyTrack/community` repository
- Please use the Zoom chat to ask questions during the presentation
- There will be an open Q&A section towards the end

Agenda

1. Upcoming Releases: v4.14.0
2. Notice: Changes to OSS Index
3. v5 Update
4. Q&A

Upcoming Releases

Upcoming Releases: v4.14.0

- Introduced distro-aware version matching.
  - Relies on PURL, so *does not* work with CPE data from the NVD.
  - Works for Alpine, Debian, and Ubuntu, using OSV data.
  - See last community meeting for more in-depth explanation.
- Added support for CVSSv4.
- GitHub Advisories: Added support for EPSS.
  - i.e. `GHSA-xxxx` vulnerabilities can now have EPSS percentiles and scores
- Will reset watermarks for incremental vulnerability source mirroring during upgrade, to allow for backfill of CVSSv4 and EPSS data.
- Working towards release by Monday next week.

Notice:
Changes to OSS Index

Notice: Changes to OSS Index

OSS Index API Transition to Sonatype Guide #5868

brianf started this conversation in General

brianf 1 hour ago

edited

I want to provide early notice of an upcoming change to OSS Index.
For many years, OSS Index has delivered free, high-quality open source vulnerability intelligence to the broader ecosystem, including users of tools such as Dependency-Track. As modern development practices evolve, particularly with automation and AI-assisted coding, the way risk is introduced into software has changed. In response, we are evolving our strategy.

Over the coming weeks, the OSS Index API will transition into Sonatype Guide.

Please note:
The OSS Index API will continue to be available via compatibility API in Sonatype Guide, with a free tier and much improved UX.
Credit limits are not yet being enforced but will begin April 28
Clear options will be provided for users to either continue using OSS Index or transition to Guide capabilities as their needs evolve
We will share more detailed guidance ahead of any required action. For now, this is intended as advance notice so your team can plan appropriately.
Thank you for being part of the OSS Index community.,
Brian Fox
CTO, Sonatype

↑ 2

https://github.com/DependencyTrack/dependency-track/discussions/5868

Notice: Changes to OSS Index

- Starting with v4.14.0, the OSS Index API URL is configurable.
- At some point, Sonatype may deprecate the old API URL, requiring you to update it to a Sonatype Guide URL.

v5 Update

v5 Update

- Released `5.7.0-alpha.1` / `0.7.0-alpha.1` and `5.7.0-alpha.2` / `0.7.0-alpha.2`.
- Removed Kafka requirement from vulnerability analysis:
  - vulnerability-analyzer service decommissioned
  - New architecture documented: https://dependencytrack.github.io/hyades/snapshot/architecture/design/vulnerability-analysis/
- Implemented *auto-deactivation of vulnerabilities* that are no longer reported by any analyzer.
- Reworked *vulnerability alias model* for better performance and reliability.
- Added ability to designate cluster nodes as “web only”.

v5 Update (Cont.)

- Updated task scheduler to catch up on missed schedules.
- Switched from “executable WAR” distribution to standard JAR.
  - Deploying to application servers (Tomcat, WildFly) no longer possible.
  - No impact for container deployments.
- Migrated worker thread pools to virtual threads.
  - Lower resource footprint, mostly memory-related.
- Implemented pluggable caching mechanism.
  - Used for caching responses from upstream data sources, e.g. OSS Index.
  - Default implementation uses `UNLOGGED` Postgres table.
  - Could also support Redis / memcached if required.
- Entire BOM processing and project analysis pipelines migrated to durable workflows.
  - Provides resiliency, backpressure, concurrency control, priority support, observability.

v5 Update: Auto-inactivation of Vulnerabilities

- Before:
  - Analyzer **A** identifies vulnerability **V** in component **C**.
  - **A** fixes a false positive, or is disabled entirely by user.
  - **V** stays around despite not being actively reported anymore.
- Now:
  - Vulnerabilities that are no longer reported by any analyzer become *inactive*.
  - Inactive vulns are *hidden* in time series metrics, UI and `REST` API responses.
  - Pre-existing audit trail, including suppression, is *retained*.
  - When a vulnerability becomes inactive, a `VULNERABILITY_RETRACTED` notification is emitted.
  - When a vulnerability becomes active *again*, a `NEW_VULNERABILITY` notification is emitted, *unless the vulnerability was already suppressed*.
  - Analyzer failures are accounted for, i.e. errors are not considered to mean “no longer reported”.

v5 Update: Auto-inactivation of Vulnerabilities

- We track *which analyzer* reported *which vulnerability*, and *when it stopped reporting it*.
- We could expose this new metadata eventually, to:
  - Enable users to see when multiple analyzers report the same vulnerability.
  - Enable users to trace when false positives were resolved.
  - etc.

https://dependencytrack.github.io/hyades/snapshot/architecture/decisions/013-finding-status/

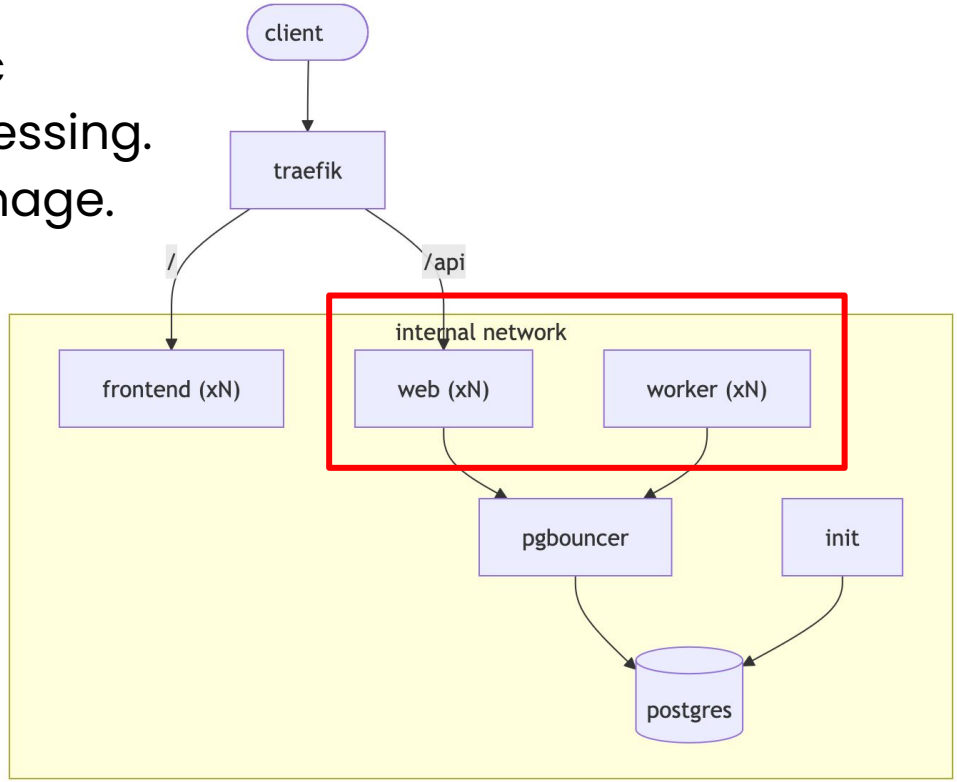
v5 Update: Refactor of Vulnerability Alias Model

- We now track *which source* asserts *which alias relationship*.
  - e.g. OSV asserts `GHSA-123` aliases `CVE-123`,
    Snyk asserts `SNYK-123` aliases `GHSA-123`, etc.
- Effective alias groups are computed based on all assertions.
  - Handles data quality fixes, e.g. when OSV *removes* an alias assertion.
  - Allows us to trace which source provided “bad” data.
- This new data is not yet exposed anywhere, but could be eventually.

https://dependencytrack.github.io/hyades/snapshot/architecture/decisions/014-new-alias-schema/

v5 Update: Web-only Cluster Nodes

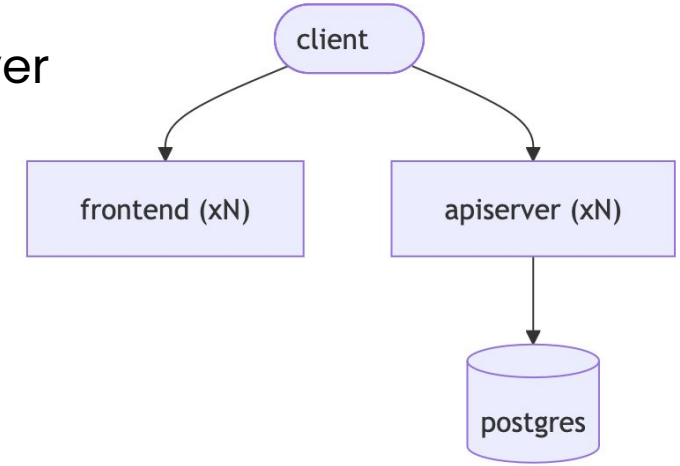
- Enables separation of web traffic handling from background processing.
- Same application & container image.
- Just a simple config option.



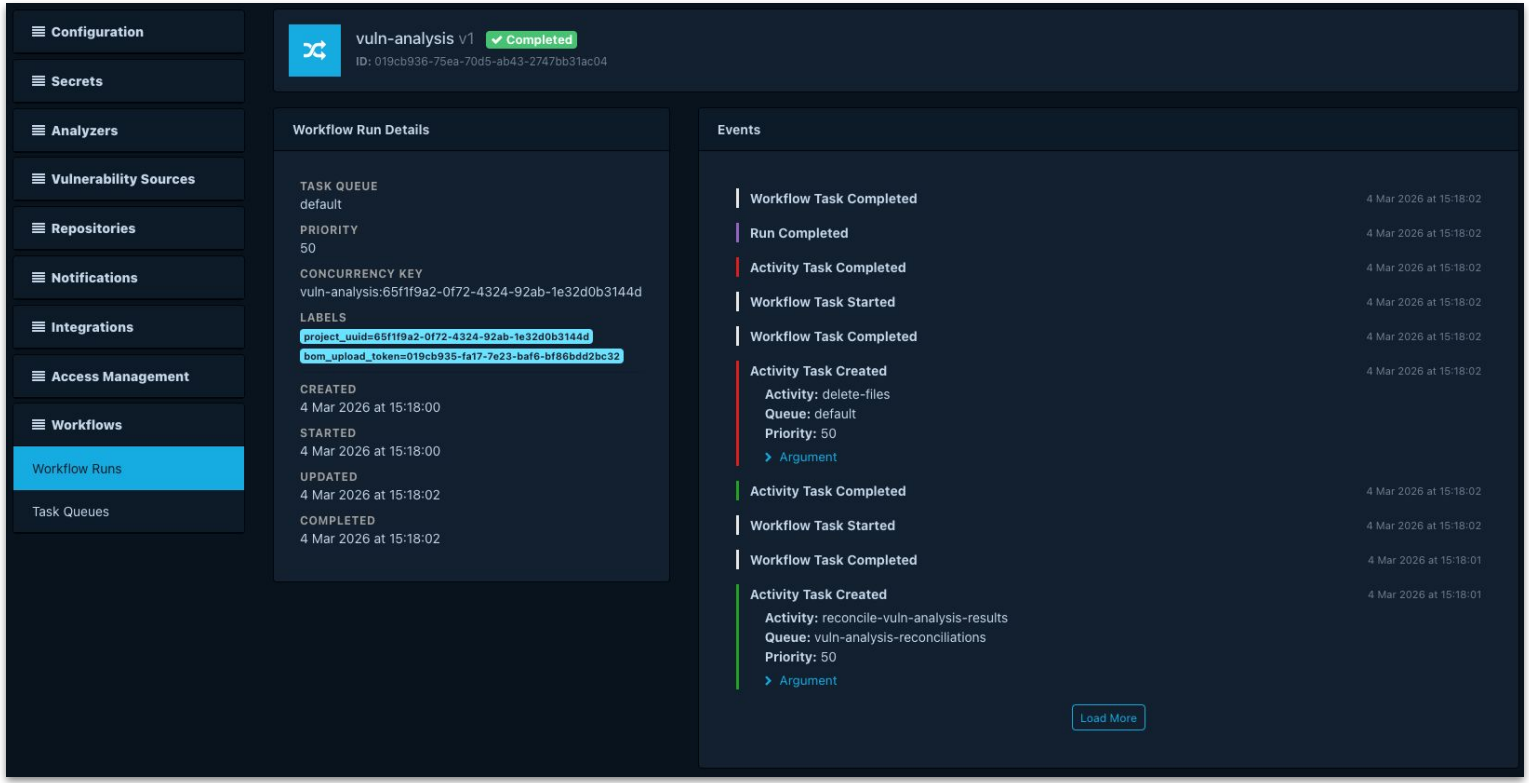
Note: It is also possible to build your own "profiles" and enable / disable specific features as you please. But the web / worker separation is easier to grasp and support.

v5 Update: Minimal Deployment

- No changes over v4, except that apiserver can be scaled horizontally if needed.



v5 Update: Workflow Details



Admins can view workflow details and their full event history

v5 Update: Task Queue Management

Home / Task Queues

- Configuration
- Secrets
- Analyzers
- Vulnerability Sources
- Repositories
- Notifications
- Integrations
- Access Management
- Workflows
- Workflow Runs
- Task Queues

Workflow | Activity

Name	Status	Capacity	Depth	Created	Updated
artifact-imports	Active	25	0	4 Mar 2026 at 15:16:23	-
default	Active	1000	0	4 Mar 2026 at 15:16:23	-
metrics-updates	Active	25	0	4 Mar 2026 at 15:16:23	-
notifications	Paused	25	0	4 Mar 2026 at 15:16:23	4 Mar 2026 at 15:18:52
policy-evaluations	Active	25	0	4 Mar 2026 at 15:16:23	-
vuln-analyses	Active	25	0	4 Mar 2026 at 15:16:23	-
vuln-analysis-reconciliations	Active	25	0	4 Mar 2026 at 15:16:23	-

‹ Previous Rows per page: 10 Next ›

Admins can pause / resume queues, and modify their capacity

v5 Update: Currently in Progress

- Dropping Kafka requirement for component metadata fetching.
  - e.g. latest version, hashes, publish dates.
  - This will finally conclude the Kafka removal!
- Documentation, particularly around deployment and operations.
- Porting changes from recent v4 releases…
- Still (optimistically) aiming for GA by end of Q1 🤞

Q&A